PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Hygiène informatique et sécurisation du SI

03-50 ANSSI - Guide d'hygiène informatique — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Identifier les données sensibles et les serveurs ou postes critiques, puis maintenir à jour un schéma du réseau.
2. Les comptes nominatifs garantissent l'imputabilité ; l'authentification forte (carte à puce, jeton) doit être privilégiée.
3. Les correctifs de sécurité doivent être appliqués dans le mois suivant leur publication.

Synthèse de la sensibilisation et de la formation

Notion	À retenir
Équipes opérationnelles	Formations régulières requises sur **législation**, **risques**, **durcissement** ou **journalisation**. Exigence à inclure dans les **contrats des prestataires**.
Utilisateurs	Information dès l'arrivée sur **enjeux**, **règles**, **informations sensibles**, **obligations légales** et **consignes quotidiennes** (ex: **verrouillage de session**). Utiliser une **charte signée**.
Infogérance	Évaluer les **risques en amont**. Imposer des exigences via un **plan d'assurance sécurité**. Contrat prévoyant **réversibilité**, **audits** et **maintien du niveau de sécurité**.

Synthèse de la connaissance du SI

Notion	À retenir
Cartographie et inventaire	Identifier les **données sensibles** pour localiser les **serveurs et postes critiques**. Maintenir un **schéma du réseau** (zones IP, interconnexions, équipements de sécurité).
Gestion des comptes privilégiés	Tenir un **inventaire exhaustif** des comptes (droits administrateurs ou accès données sensibles). Effectuer une **revue périodique** pour supprimer les **accès obsolètes**.
Gestion des entrées et sorties	Définir avec les **RH** les procédures d'arrivée/départ. Couvrir les **comptes informatiques**, les **accès physiques** et la **restitution des équipements mobiles**.
Maîtrise des équipements connectés	Autoriser uniquement les **équipements maîtrisés** sur le réseau filaire ou sans fil. Utiliser l'authentification **802.1X** pour renforcer le contrôle.

Synthèse de l'authentification et des accès

Notion	À retenir
Identification et authentification	Comptes **nominatifs** pour l'imputabilité. Compte **administrateur dédié** distinct du compte **utilisateur standard**. Privilégier l'**authentification forte** (deux facteurs : carte à puce ou jeton).
Gestion des mots de passe	Respecter la **robustesse**. **Pas de réutilisation** entre sphère privée et professionnelle. Modifier les **éléments par défaut** dès l'installation. Stockage via **coffres-forts numériques** ou **chiffrés**.
Gestion des droits d'accès	Accès aux **ressources sensibles** (fichiers de configuration, bases de données) **strictement limité** aux personnes autorisées. Effectuer une **revue régulière** pour corriger les accès illégitimes.

Sécurisation des postes

Notion	À retenir
Durcissement du parc	Appliquer **antivirus**, **pare-feu local** et **chiffrement des données**. Désactiver les **exécutions automatiques**, limiter les **applications** au strict nécessaire et chiffrer les **données sensibles** via Internet.
Gestion et supports	Utiliser un **outil de gestion centralisée**. Encadrer les **supports amovibles**, proscrire les **clés USB inconnues** et activer le **pare-feu local** contre les **déplacements latéraux**.

Synthèse de la sécurisation réseau

Notion	À retenir
Segmentation/cloisonnement	Segmenter en **zones homogènes** selon criticité/besoins. Utiliser des **pare-feu** pour filtrer les échanges. Isoler les services Internet en **zone démilitarisée** avec **relais applicatifs**.
Flux et accès distants	Remplacer protocoles clairs par **HTTPS** ou **SSH**. Accès Internet via **passerelle sécurisée** (**serveur mandataire** + **antivirus**). Interconnexions partenaires : filtrage strict et **tunnels IPsec** via Internet.
Wi-Fi et messagerie	Wi-Fi : chiffrement **WPA2** et authentification terminaux. Terminaux invités/personnels : **réseau séparé** sans accès SI. Messagerie : **antivirus** et **authentification des domaines émetteurs**.
Sécurité physique	Salles serveurs/locaux techniques : accès contrôlé par **badge** ou **serrure** et **tracé**. Espaces publics : **désactiver les prises réseau** pour empêcher les connexions sauvages.

Sécurisation de l'administration

Notion	À retenir
Isolement des fonctions	Pas d'accès direct à **Internet** ni à la **messagerie**. Réseau **dédié et cloisonné** (physique ou logique). Mises à jour via **source sûre**.
Limitation des privilèges	Pas de **droits d'administration** pour les utilisateurs. Élévation de privilèges : doit être **tracée**, **limitée dans le temps** et **retirée ensuite**.

Synthèse de la gestion du nomadisme

Notion	À retenir
Protection équipements	Banaliser les terminaux, utiliser des **filtres de confidentialité** et effectuer un **chiffrement intégral du disque dur**.
Connexions distantes	Utiliser un **tunnel VPN IPsec non débrayable** par l'utilisateur et privilégier l'**authentification forte**.
Gestion terminaux	Ne pas **mélanger usages professionnels et personnels** sur tablettes/ordiphones ; utiliser une **gestion centralisée** des flottes.

Maintenance du SI

Notion	À retenir
Gestion des correctifs	Appliquer les correctifs de sécurité dans le **mois suivant** leur publication. S'informer via les alertes du **CERT-FR**.
Gestion de l'obsolescence	Anticiper la **fin de maintenance** des logiciels/systèmes. **Isoler du réseau** les composants obsolètes irremplaçables.

Synthèse de la supervision et de la réaction

Notion	À retenir
Journalisation et surveillance	Journaliser et conserver les **événements critiques** (pare-feu, serveurs). Utiliser **NTP** pour la synchronisation temporelle et la corrélation.
Sauvegardes et continuité	Définir **données vitales**, **fréquence** et **restauration**. Stocker en **lieu sûr** et **tester régulièrement** l'exploitabilité.
Audits et gestion des incidents	Réaliser des **audits réguliers**. Désigner un **référent SSI** connu de tous. Isoler les machines compromises **sans les éteindre** pour l'analyse.

Analyse et confiance

Notion	À retenir
Analyse de risques	Une analyse **formelle** est nécessaire pour adapter les mesures aux **enjeux spécifiques** de l'entité. La méthode **EBIOS** exprime les besoins et objectifs.
Qualification et confiance	Privilégier les produits/services **qualifiés par l'ANSSI**. Les prestataires qualifiés (**PASSI** ou **PRIS**) offrent des garanties de **compétence** et de **confiance**.

Pièges et confusions

- ⚠ Croire que la sécurité est une option plutôt qu'une nécessité économique et stratégique.
- ⚠ Confondre l'application des mesures de niveau standard avec le niveau renforcé.
- ⚠ Utiliser les configurations par défaut des équipements sans les modifier.
- ⚠ Négliger la sensibilisation de l'utilisateur qui est la première porte d'entrée des attaquants.
- ⚠ Stocker des mots de passe sur des post-it ou des fichiers non protégés.
- ⚠ Rediriger la messagerie professionnelle vers une boîte personnelle.

Sigles et définitions

ANSSI Agence nationale de la sécurité des systèmes d'information qui édite ce guide.
SI Système d'Information représentant le berceau des données de l'entité.
RSSI Responsable de la Sécurité des Systèmes d'Information qui pilote la politique de sécurité.
PAS Plan d'Assurance Sécurité, document contractuel décrivant les dispositions de sécurité d'un prestataire.
EBIOS Méthode d'analyse de risques recommandée par l'ANSSI.
PASSI Prestataire d'Audit de la Sécurité des Systèmes d'Information qualifié par l'ANSSI.

Auto-test

1. Quelle méthode d'analyse de risques est recommandée par l'ANSSI ?
2. Quel protocole assure la sécurisation des échanges réseaux via des tunnels ?
3. Que doit-on faire des machines compromises lors d'un incident ?
4. Quel outil permet de segmenter logiquement un réseau ?
5. Comment doit être géré le compte administrateur par rapport au compte utilisateur ?

Réponses : **1.** EBIOS · **2.** IPsec · **3.** Les isoler sans les éteindre · **4.** VLAN · **5.** Il doit être dédié et distinct

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.